REPORT TECNICO INCIDENT RESPONSE

Analisi Forense & Digital Forensics - Lab "Brutus" (Hack The Box)

Autore:	Junior SOC Analyst / Cybersecurity Specialist	**Piattaforma:**	Hack The Box (Sherlock)
Categoria:	DFIR (Digital Forensics & Incident Response)	**Difficoltà:**	Very Easy
Stato Lab:	**Completato (100%)**	**Oggetto:**	Analisi Log Unix (auth.log, wtmp)

1. CASE OVERVIEW & SCOPE

Il presente documento analizza l'incidente informatico rilevato su un server aziendale ospitante servizi critici (tra cui un'istanza Confluence e un demone OpenSSH). L'analisi forense è stata condotta a seguito di anomalie segnalate sui sistemi di autenticazione del server Linux.

Obiettivo dell'Indagine: Ricostruire integralmente la catena d'attacco (Kill Chain) dell'avversario a partire dai registri di sistema forniti, identificando il vettore d'accesso iniziale, le credenziali violate, le sessioni stabilite, le strategie di persistenza implementate e l'eventuale esecuzione di script secondari con privilegi elevati.

Artefatti Analizzati:

- `auth.log`: Registro standard di sistema per gli eventi di autenticazione PAM, demone SSH e sessioni `sudo`.
- `wtmp`: File binario di tracciamento storico degli accessi interattivi utenti e delle sessioni terminale (allocazione PTY/PTS).

2. TIMELINE DELL'INVESTIGAZIONE

L'indagine si è svolta seguendo una metodologia rigorosa basata sulla correlazione temporale degli eventi nei log di sistema:

Fase	Azione Investigativa	Esito & Note Operative
1. Detection	Filtraggio dei tentativi SSH in `auth.log` tramite utility CLI (`grep`).	Individuato l'indirizzo IP remoto sorgente dell'attacco di forza bruta.
2. Compromissione	Isolamento dell'evento di autenticazione riuscita (`Accepted password`).	Identificato l'account amministrativo violato tramite tentativi ripetuti.
3. Correlazione	Parsing binario del file `wtmp` e analisi di `systemd-logind`.	Distinto il timestamp di rete dall'accesso interattivo e identificato il Session ID di sistema.
4. Persistence	Verifica dei log PAM relativi a `useradd/usermod`.	Scoperta la creazione di un account backdoor elevato al gruppo `sudo`.
5. Post-Exploit	Analisi dell'attività dell'account di persistenza sui log `sudo`.	Rilevata l'esecuzione di comandi privilegiati e il download di script esterni via `curl`.

3. EVIDENZE E REPERTI CHIAVE

Dall'analisi incrociata dei log sono emerse le seguenti evidenze tecniche (omettendo le flag per rispetto delle policy di piattaforma):

- **Vettore d'Ingresso:** L'attaccante ha effettuato un attacco Brute-Force mirato da un singolo IP pubblico indirizzato al servizio SSH, ottenendo le credenziali dell'account principale di sistema.
- **Assegnazione Sessione:** All'autenticazione è seguita la creazione di una sessione interattiva gestita da `systemd-logind` con un ID sessione numerico a due cifre dedicato.
- **Persistenza (MITRE ATT&CK T1136.001):** L'attaccante ha garantito la persistenza creando un nuovo utente locale e aggiungendolo manualmente ai gruppi con privilegi elevati (`sudo` / `shadow`).
- **Comando Privilegiato:** Attraverso la nuova identità compromessa, è stato eseguito un comando `sudo` completo utilizzando l'utility `/usr/bin/curl` per scaricare ed eseguire un payload di enumeration da una repository pubblica.

4. LESSONS LEARNED & AZIONI DI MIGLIORAMENTO

Raccomandazioni Difensive per l'Infrastruttura:

- **Hardening SSH:** Disabilitare il login diretto dell'utente `root` (`PermitRootLogin no`) e imporre l'autenticazione esclusiva tramite chiavi SSH.
- **Protezione Brute-Force:** Implementare soluzioni come *Fail2ban* o regole SIEM automatiche per la disabilitazione temporanea degli IP con un alto numero di fallimenti PAM.
- **Monitoring & Alerting:** Configurare alert specifici in tempo reale sul SIEM all'atto della creazione di nuovi utenti locali o modifiche ai gruppi amministrativi (`sudo`).